Advanced IT Security

Joachim Posegga

Chair of IT Security

Agenda

0 Basics

1 Symmetric Cryptography

2 Asymmetric Schemes (PKI)

3 Authentication

4 Access Control

5 Crypto-Protocols

6 „real-life“ Protocols:

- SSL/SSH
- possibly others (depending on time left)

© J. Posegga, PIDS

Why, after all, do we need Security?

LLMs

Because some ~~people~~ do not behave as we want them to!



© J. Posegga, PIDS

What does Security Mean?

“X is secure” is meaningless as an isolated statement:

- A system can only be secure *against* something
  - First job: Identify threats and security goals
- Security is a relative notion
  - “How much effort (time, money,…) does an attacker have to invest to compromise a system
  - Cost/benefit ration of security investment is a must!
- Security technology = technical means for risk management

© J. Posegga, PIDS

Elements of Security

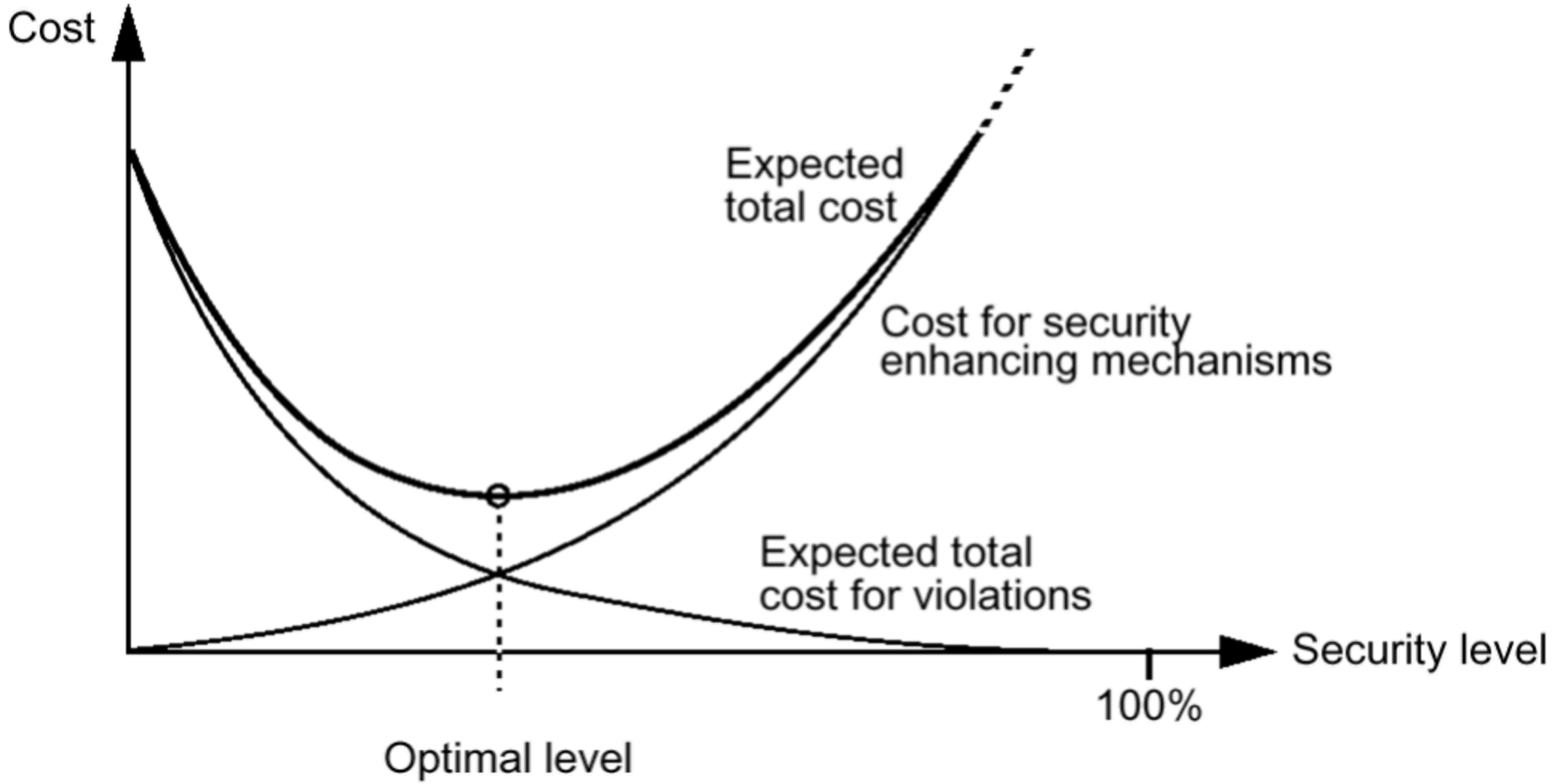
Policy: ***Specifying*** **security**
What is it supposed to do?

Mechanism: ***Implementing*** **security**
How does it do it?

Assurance: ***Correctness*** **of security**
Does it really work?

© J. Posegga, PIDS

Cost vs. benefit



© J. Posegga, PIDS

General Remarks on Risk

People perform extremely poorly with managing technical risk

Risk and emotion are inseparable.

- **We fear spectacular, unlikely events**
- **Anything new is suspicious**
- **Anything invisible is suspicious**
- **Correlation is often confused with causality**

Greater Fear	Less Fear
Imposed (nuclear accident radiation)	**Voluntary** (medical radiation)
More **Pain and Suffering** (cancer)	Less **Pain and Suffering** (heart disease)
Human-made (radiation from technology)	**Natural** (radiation from the sun)
Less Benefit (vaccines for diseases that have been mostly eliminated)	**More Benefit** (vaccines for new strains of influenza – H1N1/"Swine flu")
Uncertainty (nuclear radiation - because we can't detect it, science doesn't have all the answers, or we don't understand all the science.)	**Certainty/Familiarity** – (motor vehicle crashes)
Risks to Children (childhood vaccines)	**Risks to Adults** (adult vaccines)

Slovic P, The Perception of Risk, Earthscan 2000

© J. Posegga, PIDS

Risk Perception

What's more common in the United States, (a) suicide or (b) homicide?

Who has a higher risk of being murdered: Women or men?

Global victims: female 21%, male 79%

What is the top cause of accidental death in America, following motor-vehicle accidents?

Drug overdose

Of the top two causes of non-accidental death in America, (a) cancer and (b) heart disease, which kills more women?

© J. Posegga, PIDS

Risk Perception

Worldwide annual fatalities:

Shark attacks = 10

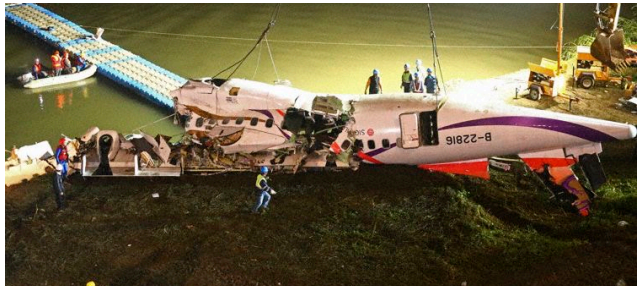
Getting hit on the head with a coconut = 150

The per-flight risk of dying in a commercial airline crash between 2000 and 2007 was 1 in 80 million

The per-trip risk of dying in an automobile crash, given the average American car trip of 6 miles, was 1 in 14.6 million.

95 % of people who are involved in a plane crash survive





© J. Posegga, PIDS

… for the sake of confusion:

Germany 2008: deaths per billion km and year (OECD)

- **Rail:** 0.2
- **Air:** 0.4
- **Motorcycle:** 45
- **Car:** 6
- **Bycyle:** 30
- **Pedestrian:** 38

Actual number of deaths (2012):

Road User Type	Motorcycles	583
	Passenger Cars	1 655
	Cyclists	387
	Pedestrians	453

© J. Posegga, PIDS

GSM-Security: Political Constraints

Export of Cryptographic Technology:

- An internationally rolled out system (Roaming!) must comply with international regulations regarding export control

“Lawful Interception”:

- Goernment regulations require to provide means for certain authorities to intercept data.

Examples:

- IMSI-Catcher (“man-in-the-middle attack”) are possible since the GSM network does not authenticate against the client.
- Access to the history of location information tells a lot!

© J. Posegga, PIDS

Definitions

© J. Posegga, PIDS

Elements auf Security...

- assets,
- threats,
- vulnerabilities,
- impact,
- risk,
- safeguards,
- residual risk,
- constraints.

© J. Posegga, PIDS

Assets...

Everything that has a value

- Information and Data,
- Hardware,
- Software,
- other Equipment,
- documents,
- services,
- “trust” in services,
- personell,
- A organization’s image,...

© J. Posegga, PIDS

Threats

Everything that potentially harms Assets

- errors, faults,
- misuse and theft,
- malicious code,
- hacking,
- sabotage,
- espionage,...

© J. Posegga, PIDS

Vulnerabilities

"Vulnerabilities are weaknesses which allow a threat to occur"

(Vulns do not neccesarily cause damage)

Examples:

- Insecure communication,
- Poorly trained staff,
- Trivial passwords,
- Poor access control,
- Lack of Back-ups,...

© J. Posegga, PIDS

Safeguards

Means to reduce threats or vulnerabilities

Example: Access Control, Encryption, training of personell,...

- ETSI Baseline Security Standard
- NIST Computer Security Handbook
- ISO TC 68 Banking and Related Financial Services - Information Security Guidelines
- ...

© J. Posegga, PIDS

Risks...

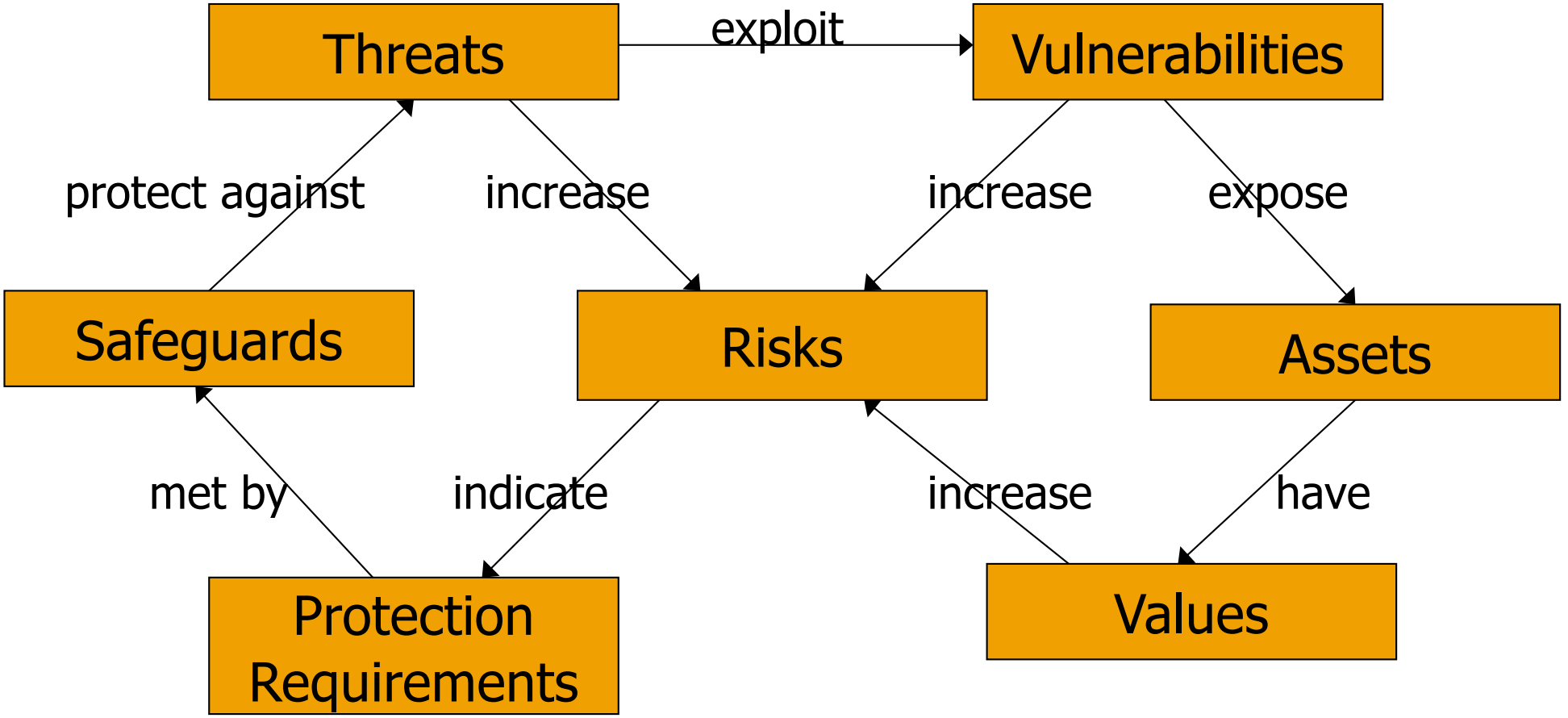
Risk is a Function of:

- Assets,
- Threats,
- Vulnerabilities,
- Safeguards.

There always remains a Residual Risk

© J. Posegga, PIDS

Beziehungen



© J. Posegga, PIDS

Basic Notions

Confidentiality: no unauthorized access to Information

Integrity: no unauthorized modification of information / resources

Availability: no unauthorized denial of access to information / resources

(according to ITSEC)

© J. Posegga, PIDS

Confidentiality

Historically, security and secrecy were closely related. Sometimes, security and confidentiality are used as synonyms

- **Prevent unauthorised disclosure of information (prevent unauthorised reading)**
- **Privacy: protection of personal data**
- **Secrecy: protection of data belonging to an organisation**

© J. Posegga, PIDS

Integrity

Everyting is as it is supposed to be...

© J. Posegga, PIDS

Integrity – Other definitions – Overview

Property or state, or?

Clark and Wilson: No user of the system, even if authorized, may be permitted to modify data items in such a way that assets or accounting records of the company are lost or corrupted.

Orange Book (TCSEC): Data Integrity - The state that exists when computerized data is the same as that in the source document and has not been exposed to accidental or malicious alteration or destruction.

In communications: detection (and correction) of modifications of transmitted data, including both intentional modifications and random transmission errors.

ISO 7498-2: The property that information has not been modified or destroyed in an unauthorized manner.

ISO 27000: property of accuracy and completeness

RFC 4949: The property that data has not been changed, destroyed, or lost in an unauthorized or accidental manner.

© J. Posegga, PIDS

Is Integrity a property or a state?

Property is any characteristic or attribute which can be quantitatively evaluated.

- Examples from physics: pressure, temperature, velocity, energy, etc. are all properties

The **state** of an object is its condition described by a list of properties.

- Example: temperature and pressure may describe the state of a gas

View on Integrity:

Integrity is a property (of data, of a system, of hardware,…)

Data Integrity is a specific state of data that is verifiable.

© J. Posegga, PIDS

Integrity – Other definitions – Overview

Detection or prevention ?

Clark and Wilson: No user of the system, even if authorized, may be permitted to modify data items in such a way that assets or accounting records of the company are lost or corrupted.

Orange Book (TCSEC): Data Integrity - The state that exists when computerized data is the same as that in the source document and has not been exposed to accidental or malicious alteration or destruction.

In communications: detection (and correction) of modifications of transmitted data, including both intentional modifications and random transmission errors.

ISO 7498-2: The property that information has not been modified or destroyed in an unauthorized manner.

ISO 27000: property of accuracy and completeness

RFC 4949: The property that data has not been changed, destroyed, or lost in an unauthorized or accidental manner.

© J. Posegga, PIDS

Other definitions – Overview

What to detect ?

Clark and Wilson: No user of the system, even if authorized, may be permitted to modify data items in such a way that assets or accounting records of the company are lost or corrupted. ← Preventative

Orange Book (TCSEC): Data Integrity - The state that exists when computerized data is the same as that in the source document and has not been exposed to accidental or malicious alteration or destruction.

In communications: detection (and correction) of modifications of transmitted data, including both intentional modifications and random transmission errors.

ISO 7498-2: The property that information has not been modified or destroyed in an unauthorized manner.

ISO 27000: property of accuracy and completeness

RFC 4949: The property that data has not been changed, destroyed, or lost in an unauthorized or accidental manner.

© J. Posegga, PIDS

Internal vs. external consistency

Note 3: Integrity definition sees data integrity as “a specific invariant on data” [ISO 10181-6]. Following this, the integrity protection mechanism “detects the violation of internal consistency” [ISO 10181-6]. “A datum is internally consistent if and only if all modifications of this item satisfy the relevant integrity security policies.” [ISO 10181-6]

Note 4: Integrity definition is not concerned with the external consistency or veracity of the data.

Q: Assume a temperature sensor that is attached to an IoT device is broken, i.e. readings are too high.

Assume the IoT device signs the temperature measurements data, i.e. readings are digitally signed.

Should an integrity verification of the signed but wrong temperature value fail or succeed?

© J. Posegga, PIDS

Availability

- ISO 7498-2: the property of being accessible and usable upon demand by an authorised entity

- Denial of Service: The prevention of authorised access of resources or the delaying of time-critical operations

-> Denial-of-Service is hard to prevent in real life!

© J. Posegga, PIDS

Security Evaluation

"Security evaluation checks whether a product delivers a promised security service. We have to state the function of the security system the required degree of assurance (trust) in its security"

(D. Gollmann)

- **A high level of Assurance-Level implies an inspection of a system at a very detailed level.**
- **Complex systems and a high levels of assurance tend to me mutually exclusive**

© J. Posegga, PIDS